

Phishing and Human Vulnerability: Why Technology Fails When Humans Become the Entry Point

A development proposal for an MSc in cybersecurity, focused on the vulnerability surface between social engineering and human decision-making - not just technical controls.

Karina Sætersdal Nilssen · draft updated 27 August 2026 · version 3 (English) · status: direction chosen

Why this direction

The thesis direction points toward phishing - and it connects to work you have already explored.

Across conversations, labs, and coursework, the same pattern appears: many serious incidents do not start with "movie-style hacking", but with a person who clicks, trusts, rushes, or misunderstands. Technical controls exist, but attackers still often succeed via **trust, urgency, and cognitive overload**.

The focus is the **vulnerability surface between phishing and the human**: not only what phishing is, but *why* it still works, *who* is most vulnerable, and *what* actually reduces risk in practice.

Human factors

Social engineering

Phishing

Decision under pressure

Awareness vs. behaviour

AI-enhanced fraud

Core hypothesis: loneliness, skepticism, and hidden vulnerability

In a time of both rising loneliness and rising general skepticism, phishing becomes dangerous precisely because it does not look like an attack from a stranger. It imitates what people still long for or fear losing: belonging, safety, order, status, help, and control.

This is the thesis's central theoretical tension. Many assume that rising digital skepticism automatically makes us safer. But phishing rarely exploits what we are most skeptical of - **complete strangers**. It exploits what we remain receptive to: what feels **familiar, important, helpful, or urgent**.

The paradox the thesis will investigate

Rising loneliness and digital dependence

- Greater need for belonging and validation
- More people seek contact, help, and response online
- Emotional lures can feel more meaningful than technical ones

Rising general skepticism

- More people have heard about fraud, phishing, and hacking
- More "be wary of strangers" rhetoric
- Greater awareness of digital threats than before

The conflict arises when these two trends meet: people can be **generally skeptical**, yet still vulnerable to attacks that imitate what they emotionally or socially need. The thesis should therefore not ask "why do people trust strangers?", but rather:

Why does manipulation that appears relevant, safe, or socially meaningful still work - even in a time when we are more skeptical than ever?

Working title

English (recommended): Phishing Between Loneliness and Skepticism: How Social Engineering Exploits the Human Need for Belonging, Safety, and Control

Previous working title: Phishing and Human Vulnerability: A Study of Why Users Still Fall for Social Engineering

The final title can be refined once methodology and data sources are confirmed with the supervisor.

Research problem

Organisations invest in security technology, training, and policy - yet phishing remains one of the most common and effective entry points to larger attacks.

This suggests the problem is not only technical, but lies in the **meeting point between attack and human behaviour**: how we assess senders, handle authority and urgency, and respond under uncertainty. Especially relevant is the tension between **loneliness** and **skepticism**: people may be more cautious toward the unknown, yet still vulnerable when an attack imitates what they long for or fear losing.

Core idea: Phishing is not just an "IT problem". It is an attack on how people think, feel, and act under pressure - and on needs such as belonging, safety, order, status, help, and control.

Main research question (draft):

How can phishing remain effective in a time characterised by both rising loneliness and rising general skepticism, and which human and contextual factors make individuals especially vulnerable to this form of social engineering?

Previous directions considered

Several topics were evaluated. The phishing direction connects several of them without becoming too broad.

CHOSEN MAIN DIRECTION

Phishing and human vulnerability

Focus on why users click, trust, and act unsafely - and what actually helps.

SUPPORTING PERSPECTIVE

Attack chain after phishing

Session hijacking, account takeover, data theft, and ransomware as a possible consequence chapter.

SUPPORTING PERSPECTIVE

Privacy / cookies / third parties

Relevant as background on trust, tracking, and user understanding - not main focus.

REJECTED AS MAIN FOCUS

Ransomware alone

Important, but often "late in the chain". Phishing is a better starting point for human-factor analysis.

Research questions (revised draft)

1. **Why** does phishing still work in a time of rising digital skepticism and fraud awareness?
2. **How do emotional and social needs** - such as loneliness, need for belonging, fear of loss, and desire for control - affect vulnerability to phishing and social engineering?
3. **Which situational factors** (urgency, authority, stress, shame, information overload) lead users to click or disclose information even when they "know better"?
4. **Which measures** (training, procedures, technical controls, reporting culture) are experienced as most effective for reducing risk in practice?

These can be narrowed to 2-3 main questions. Questions 1 and 2 are now the core of the theoretical direction.

What phishing imitates - and why it works

The thesis should analyse phishing as **imitation of legitimate human and institutional needs**, not merely as technical fraud.

Need / fear	Phishing example	Why it may work
Belonging	"Someone tried to contact you", colleague impersonation, romance scams	Creates a sense of social relevance and closeness
Safety	"Your account is compromised - verify now"	Exploits fear and the desire to protect oneself
Order / control	Tax authority, bank, supplier, "unpaid invoice"	Appeals to the wish to fix things quickly
Status / identity	Job offer, exclusive access, "you have been selected"	Appeals to self-image and recognition
Help	IT support, "click here and we will fix it"	Exploits helpfulness and technical uncertainty
Control over consequences	Urgency, threats, deadlines	Reduces time for critical evaluation

Vulnerability markers - not "character flaws"

The thesis should avoid framing this as certain people being "stupid" or having poor traits. A better term: **vulnerability markers** - conditions that increase the likelihood of poor decisions under manipulation.

Type	Examples	Important nuance
Emotional factors	Loneliness, stress, fear, shame, FOMO	Increases receptivity to lures that feel meaningful
Cognitive factors	Multitasking, urgency, information overload	Reduces ability to pause in the moment
Social factors	Authority orientation, helpfulness, conflict avoidance	Often positive traits in everyday life, exploited in attacks
System factors	Poor routines, high tempo, difficult verification	Makes the safe action hard even for aware users

Loneliness is a central but not sole risk factor. The thesis should examine it alongside stress, trust, authority, and digital competence.

Theoretical framework (proposal)

Theory / perspective	Why it is relevant
Human factors / human-computer interaction	Explains how design, cognitive load, and user behaviour create vulnerability.
Protection Motivation Theory	Examines threat appraisal, perceived severity, and self-efficacy - why people still act riskily.
Social engineering / persuasion	Authority, urgency, fear, reciprocity, and similarity - classic psychological levers in phishing.
Security culture and organisational learning	Whether people dare to ask, report, and pause without feeling foolish.
Human-as-the-weakest-link (critical)	Used as a starting point, but should be challenged: perhaps systems are designed to fail humans.
Loneliness / social connection	Explains why manipulation that appears close, helpful, or socially relevant can bypass general skepticism.
Trust paradox / skepticism gap	People may be skeptical of strangers yet vulnerable to authority, urgency, and emotionally plausible contact.

Possible methodology

Methodology need not be locked now, but these three paths are realistic for a master's thesis:

Option A: Qualitative (strong for "why")

- Interviews with employees/students/IT staff
- Topics: close encounters with phishing, what they saw, thought, and did
- Good for human decision-making, shame, and trust

Option B: Mixed methods (often best for master's)

- Short survey on experience, trust, and security behaviour
- Followed by in-depth interviews with selected respondents
- Optionally simulated phishing in a controlled setting (requires ethics approval)

Option C: Case study

- One organisation or domain (e.g. higher education / public sector)
- Analysis of policy, awareness programmes, incidents, and user experience

Current recommendation: start with *Option B* as the working hypothesis. It offers both breadth and depth, and allows discussion of human vulnerability and what actually helps.

What the thesis can claim (substance without exaggeration)

- Phishing remains one of the most important entry points to larger attacks.
- The problem is often a **human-system problem**, not merely user error.
- AI makes lures more credible but does not change basic psychology - it amplifies it.
- Awareness alone is rarely enough; culture, design, and process must support it.
- Phishing often exploits positive human traits - not only individual "deficits".
- There is a difference between "knowing about phishing" and "being able to stop oneself in the moment".
- Rising loneliness and rising skepticism can coexist - and create a new type of vulnerability.
- Phishing is dangerous because it imitates belonging, safety, order, status, help, and control.

Scope

- **Include:** email, SMS/smishing, vishing, emotional manipulation, and loneliness as a risk factor where methodologically defensible.
- **May mention but not dominate:** ransomware, session hijacking, GDPR/cookies.
- **Exclude as main focus:** deep technical malware analysis, pentesting, cryptography.
- **Geography:** Norway / Nordic context, with international literature as framework.

Proposed chapter structure

1. Introduction and research problem
2. Background: phishing as an entry point in the modern threat landscape
3. Theoretical framework: loneliness, skepticism, and human vulnerability
4. Phishing as imitation of belonging, safety, order, status, help, and control
5. Methodology
6. Findings
7. Discussion: why humans remain vulnerable in a more skeptical age
8. Conclusion and recommendations for practice

Starter literature

- Cacioppo & Patrick - loneliness and social connection as background for emotional vulnerability
- NSM - alerts and guidance on phishing and social engineering
- ENISA Threat Landscape (social engineering and human risk)
- CISA - phishing and reporting guidance
- Hadnagy, C. - *Social Engineering: The Science of Human Hacking*
- Conteh & Schmick - Protection Motivation Theory in cybersecurity
- Recent reports on AI-assisted phishing (Halcyon, Trend Micro, Microsoft Digital Defense)

Next steps

1. Book supervision and bring this document as a starting point.
2. Confirm interviews, survey, or case study - ideally within 2-3 weeks.
3. Refine the one-page problem statement for the supervisor - use the core hypothesis as the opening.
4. Build a starter reference list with 10-15 sources.
5. Decide population: students, employees, public sector, or general population.
6. Clarify ethics: NSD approval and secure handling if sensitive experiences/interviews are collected.

Internal working document for master's thesis planning. Can be developed into a formal prospectus after supervisor meeting.